Rapport d'analyse de sécurité du code

MVOGMBI_Sync — Clover → Sage 50

Version 1.0.14 (13 novembre 2026) — Marché MVOG-MBI Sherbrooke. Éditeur : Concept Informatique inc.
Version de l'application : 1.0.16
Conçu et développé par Concept Informatique inc. — Tous droits réservés.

Sommaire

1. Résultat en bref
2. Outils et périmètre
3. Constats corrigés en version 1.0.14
4. Constats examinés et acceptés
5. Constats de Bandit
6. Corrections de la revue manuelle (version 1.0.13)
7. Ce qui reste à faire hors du code
8. Règle

Ce rapport rend compte de l'analyse de sécurité demandée par le propriétaire le 13 novembre 2026 : une revue manuelle de l'application (corrigée en version 1.0.13), puis une analyse statique complète du code par **SonarQube** (corrigée en version 1.0.14), complétée par **Bandit** et **pip-audit**.

1. Résultat en bref

Indicateur SonarQube	Première analyse	Après correction (1.0.14)
Lignes de code analysées	63 474	63 484
Bugs	7	**0**
Vulnérabilités	11	**0**
Points sensibles de sécurité	0	**0**
Défauts de code (maintenabilité)	29	**0**
Note de sécurité	D	**A**
Note de fiabilité	D	**A**
Note de maintenabilité	A	**A**

Dépendances (pip-audit sur `requirements.txt`) : **aucune vulnérabilité connue**.

2. Outils et périmètre

Outil	Rôle	Périmètre
SonarQube Community (serveur local dans Docker, scanner `sonar-scanner-cli`)	Bugs, vulnérabilités, points sensibles, défauts de code	`mvogmbi_sync/` (179 modules Python), `installation/`, `documentation/` (Python, JavaScript, PowerShell) ; tests à part
Bandit 1.9	Règles de sécurité propres à Python (SQL, sous-processus, hachage, réseau)	`mvogmbi_sync/`
pip-audit	Vulnérabilités publiées (CVE) des bibliothèques	`requirements.txt`
Revue manuelle (1.0.13)	Fichiers reçus, exports, mots de passe, NIP, serveur web, chemins réseau	toute l'application

L'analyse se fait sur le poste de développement : le code n'est envoyé à aucun service externe. Pour la refaire : `installation\analyse_sonarqube.ps1` (voir le guide de l'administrateur, § 10).

3. Constats corrigés en version 1.0.14

Règle SonarQube	Gravité	Constat	Correction
S5779	Critique (bug)	`assert` dans un `try` qui attrape `AssertionError` (heure du traitement de nuit, période « Charger la période », dates des Encaissements, heure de l'automatisation web) : avec Python optimisé (`-O`), ces contrôles disparaissent	Contrôle explicite qui lève `ValueError`
S4790	Critique (vulnérabilité)	Identifiant des factures saisies (achat, chaîne des documents, page web) calculé par SHA-1 du nom et de l'heure	`uuid.uuid4()` ; les empreintes de fichiers (doublons de factures, manuel du profil) gardent SHA-1, déclaré non cryptographique (`usedforsecurity=False`) pour ne pas changer les empreintes déjà enregistrées
S8786	Majeur	Expressions régulières à retour arrière coûteux (déni de service par texte piégé) : contrôle de nombre des exports CSV, nombres des PDF, adresses courriel des fiches client / fournisseur, avis Interac reçus d'Internet	Expressions réécrites en temps linéaire ; courriel lu limité à 20 000 caractères (`paiements_courriel.LIMITE_TEXTE`) ; test `test_analyse_sonarqube_expressions_en_temps_lineaire`
S9383	Majeur (bug)	Promesse non gérée dans le script de la présentation PowerPoint	`.catch` : erreur affichée et code de sortie 1
S3923	Majeur (bug)	Condition inutile dans un message de la page des interrogations	Message simplifié
S9408	Majeur (bug)	Connexion à la base fermée dans un `finally`	`contextlib.closing`

4. Constats examinés et acceptés

Chaque constat ci-dessous a été examiné un à un, commenté dans SonarQube et classé « faux positif » ou « accepté ».

Règle	Où	Décision
S4830 « validation du certificat »	Lecture IMAP des avis Interac et des factures par courriel	**Faux positif** : `ssl.create_default_context()` vérifie le certificat et le nom du serveur
S5332 « HTTP au lieu de HTTPS »	Client (`web/client.py`)	**Accepté** : HTTPS est toujours essayé en premier ; HTTP seulement vers l'ancien port 8765, à travers le tunnel chiffré de Tailscale
S1313 « adresse IP en dur »	`serveur_appli.py`	**Accepté** : valeurs par défaut, modifiables dans Administration > Automatisation
S3516, S8495	Gestionnaires d'événements de l'interface Windows, rappels	**Faux positif** : Tk exige le retour « break » ; le rappel renvoie toujours False par contrat
S9408 (après correction)	`base_sage.py`	**Faux positif** : le curseur pymysql et `closing` sont des gestionnaires de contexte
S8786 (16 restants)	Lecture des relevés bancaires, des factures fournisseurs, des états RIA, des formats d'articles, mise en page web	**Accepté** : texte borné (une ligne de relevé ou de facture, document d'un fournisseur ou d'une banque connus, page produite par l'application) ; aucune entrée libre et illimitée d'un attaquant

5. Constats de Bandit

Règle Bandit	Nombre	Examen
B608 « SQL construit par texte »	35	**Aucune injection** : seuls des noms de tables et de colonnes fixes (choisis dans le code), des listes de `%s` ou des constantes sont insérés ; toute valeur saisie passe en paramètre de la requête
B324 « SHA-1 »	6	Corrigé (voir § 3)
B104 « 0.0.0.0 »	2	Faux positif : comparaison avec une adresse, jamais une écoute ; le serveur web écoute sur l'adresse Tailscale
B310 « urlopen »	1	Accepté : le client ne contacte que l'adresse du serveur choisie (http ou https)
B603, B606, B607, B404 (sous-processus)	80	Accepté : programmes connus (Sage, Edge, schtasks, tailscale), jamais de commande composée avec un texte saisi ni de `shell=True`
B110, B112 (`except: pass`)	39	Accepté : opérations de secours (fermeture, nettoyage) qui ne doivent jamais arrêter un traitement

6. Corrections de la revue manuelle (version 1.0.13)

Rappel des corrections faites juste avant (règles RG-SEC-10 à RG-SEC-14) : fichiers reçus reconnus par leur contenu (PDF et images seulement), aucune formule dans les exports Excel et CSV, mots de passe de 12 caractères et empreintes de

600 000 tours, attente qui s'allonge après des NIP faux, requêtes web invalides refusées et connexions inactives fermées, partages réseau refusés.

7. Ce qui reste à faire hors du code

Ces mesures dépendent de la configuration du serveur, pas du programme (guide de l'administrateur, § 10) :

1. Faire tourner l'application, le serveur web et le traitement de nuit dans une session Windows **sans droits d'administrateur**.
2. Limiter, dans la console Tailscale, les appareils des employés au **port 443** du serveur.
3. Faire changer les mots de passe de moins de 12 caractères.
4. Contrôler l'empreinte SHA-256 des installateurs (programmes non signés).

8. Règle

RG-SEC-15 : chaque version importante passe l'analyse SonarQube (`installation\analyse_sonarqube.ps1`) ; une vulnérabilité ou un bug ouvert se corrige avant la livraison, ou est examiné et classé avec sa raison dans SonarQube.